

## Incident Response Engagement Findings & Detection Report

**INC-2026-001 - Linux Infrastructure Compromise**

### CLIENT

#### NexaCorp

*Internal server intrusion investigation*

*Engagement reference INC-2026-001*

*Phase 1 forensic analysis & Phase 2 detection engineering*

Prepared by

**Johan-Emmanuel Hatchi, SOC Analyst L1**

*BeCode Cybersecurity Bootcamp - Promotion 2025-2026*

[linkedin.com/in/johan-emmanuel-hatchi](https://linkedin.com/in/johan-emmanuel-hatchi) · [github.com/Jhatchi](https://github.com/Jhatchi)

**Date: 11 May 2026**

## Table of Contents

|                                                   |    |
|---------------------------------------------------|----|
| CONFIDENTIALITY STATEMENT .....                   | 3  |
| EXECUTIVE SUMMARY .....                           | 4  |
| METHODOLOGY .....                                 | 6  |
| ATTACK TIMELINE .....                             | 8  |
| INDICATORS OF COMPROMISE .....                    | 9  |
| INVESTIGATION TECHNICAL SUMMARY .....             | 10 |
| I1-I5 (Critical/High findings) .....              | 10 |
| I6-I10 (recon, brute-force, detection gaps) ..... | 15 |
| RISK MATRIX .....                                 | 20 |
| MITRE ATT&CK MAPPING .....                        | 21 |
| DETECTION ENGINEERING (R1-R7) .....               | 22 |
| REMEDIATION .....                                 | 24 |
| TOOLS AND STANDARDS .....                         | 25 |
| GLOSSARY AND ACRONYMS .....                       | 27 |

## Confidentiality Statement

This report documents INC-2026-001 of the BeCode Corp internal cybersecurity training programme, an incident response engagement against a controlled laboratory environment simulating an internal network intrusion at the fictitious organisation NexaCorp. The target was a virtual Metasploitable 2 instance (a deliberately vulnerable Linux distribution) in the BeCode SOC lab. No real production system, customer data, or third party was involved. All identities, hostnames and accounts belong to the BeCode training environment.

This document is classified Internal - Not for distribution under reference BCC-2026 | INC-2026-001. Raw evidence is retained by BeCode Corp and is not redistributed. The auditor may share this report as part of a professional portfolio per BeCode policy.

## Disclaimer

Findings are based on the evidence package : a 5h31 network capture (9 May 20:08 UTC to 10 May 01:39 UTC), Wazuh SIEM ingestion (397 events for the affected agent) and host log snapshots. The host audit logs do not cover the incident window, and the capture begins after the initial compromise that installed the C2 implant (finding I5). The methodology follows NIST SP 800-61r2 and SANS PICERL. All timestamps are UTC.

## Executive Summary

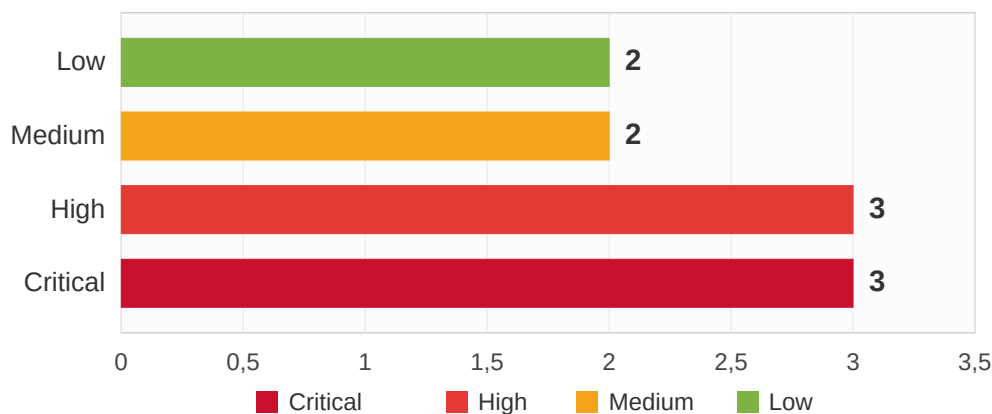
### A. Plain-language summary

On the evening of 9 May 2026 around 22:53 UTC, an external attacker compromised an internal server (192.168.10.10) by exploiting a 2011-vintage vulnerability in an outdated FTP service. They obtained administrator-level access for about 20 seconds, mapped the system, then left : no data theft, no permanent access, no lateral movement through this entry point. Separately and more concerning, the same server was already infected, running a hidden remote-control program (MITRE Caldera) beaoning out every minute : this is the unusual outbound connection IT flagged, and its origin predates the capture. The monitoring system recorded 397 events but only 4 high-priority, and none identified the actual attack or the hidden implant.

### B. Engagement summary

The investigation reconstructed a textbook opportunistic external intrusion against a vulnerable service (vsftpd 2.3.4, CVE-2011-2523) : a 15-hour low-and-slow reconnaissance phase, a single-packet exploitation, a 20-second root post-exploitation session, and a clean disengagement. It also surfaced a second, independent and higher-concern finding : a pre-existing MITRE Caldera Sandcat C2 agent beaoning in cleartext to a non-NexaCorp endpoint, indicating a prior compromise not represented in the evidence. The two incidents use different attacker IPs and are likely different actors. The segment posture is rated CRITICAL.

#### Findings by Severity Level

**B.**

### C. Overview of findings

| Ref | Description                                                          | Severity |
|-----|----------------------------------------------------------------------|----------|
| I1  | vsftpd 2.3.4 vulnerable service exposed (CVE-2011-2523)              | CRITICAL |
| I2  | Extended 15-hour low-and-slow reconnaissance phase                   | MEDIUM   |
| I3  | CVE-2011-2523 exploitation (USER smiley backdoor trigger)            | HIGH     |
| I4  | Unauthenticated root bind shell on TCP/6200 (8 enum commands)        | CRITICAL |
| I5  | Pre-existing MITRE Caldera Sandcat C2 implant (root, active beacons) | CRITICAL |
| I6  | Multi-protocol service enumeration (HTTP/SSH/SMTP/Telnet/MySQL)      | LOW      |
| I7  | SSH brute-force attempts (visible in Wazuh)                          | MEDIUM   |
| I8  | Anomalous sudo activity (two first-time-sudo events)                 | HIGH     |
| I9  | Insufficient Wazuh SIEM detection coverage (4 high alerts / 397)     | HIGH     |
| I10 | Host audit logs do not cover the incident window                     | LOW      |

## D. Overview of recommendations

| REF   | FINDING         | SHORT RECOMMENDATION                                                                                         |
|-------|-----------------|--------------------------------------------------------------------------------------------------------------|
| I1/I3 | vsftpd 2.3.4    | Decommission or upgrade vsftpd ( $\geq 3.0.x$ ); migrate to SFTP; monthly vuln scans; deploy Suricata R1/R2. |
| I4    | Root bind shell | Take the host offline, full forensic image; deny TCP/6200; deploy Suricata R3; auditd execve monitoring.     |
| I5    | Caldera C2      | P0: quarantine, image memory+disk, investigate /opt/caldera/sandcat; egress allowlist; deploy R4/R5.         |
| I9    | SIEM gap        | Author correlation rules elevating brute-force + first-time-sudo; deploy the seven Suricata rules.           |
| I10   | Host log gap    | Enable $\geq 90$ -day retention and near-real-time off-host shipping to the SIEM.                            |

## Methodology

### A. Procedure

The investigation follows NIST SP 800-61r2 and the SANS PICERL process, mapping every finding to MITRE ATT&CK Enterprise v15. It is a two-phase engagement : Phase 1 evidence-driven reconstruction (network capture, host logs, SIEM), Phase 2 detection engineering (seven Suricata rules validated by offline PCAP replay).

#### 01. Scope and evidence triage

- Validate the PCAP, host logs and SIEM exports
- Confirm the engagement boundaries



#### 02. Network attack reconstruction

- PCAP triage, per-flow TCP stream follow
- Service fingerprinting and exploit-signature identification



#### 03. Multi-source correlation

- Cross-reference host logs and 397 Wazuh events
- Severity distribution and IOC consolidation



#### 04. Detection gap analysis

- Inventory what each layer caught
- Map findings to MITRE ATT&CK; and find blind spots



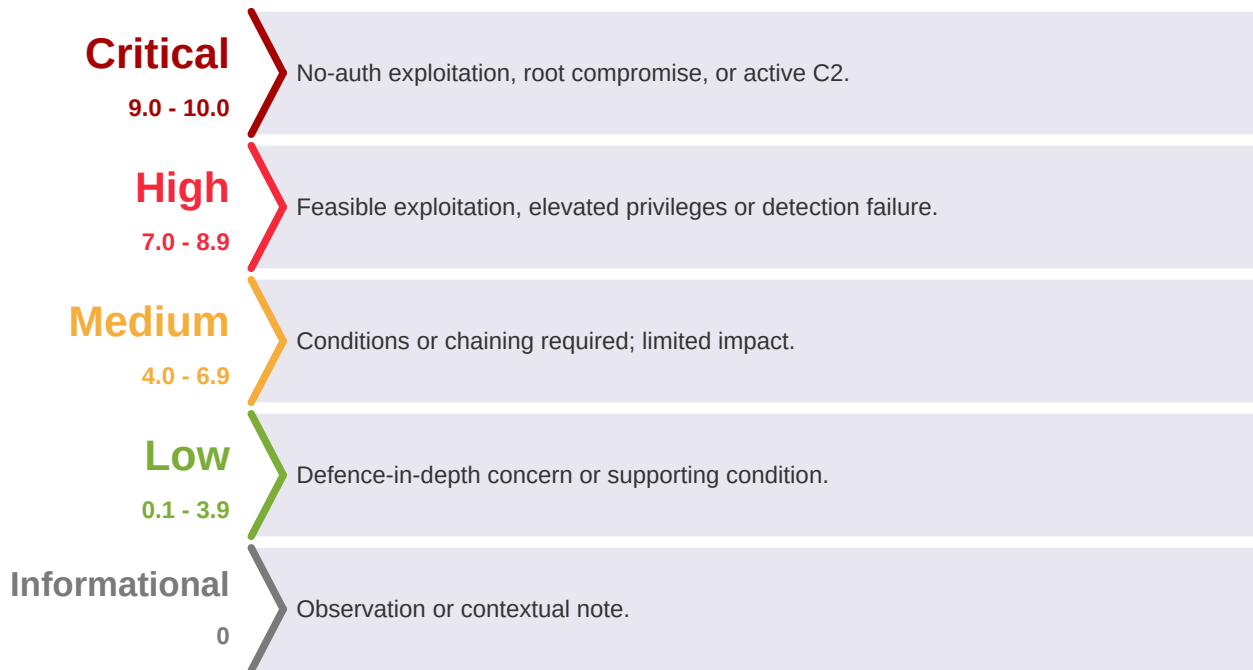
#### 05. Detection engineering and reporting

- Author seven Suricata rules
- Validate by offline replay; consolidate the report



## B. Severity ratings

Severity uses CVSS v3.1 as foundation, enhanced with a contextual likelihood factor (authentication required, network position, exploitation complexity). The full CVSS vector is given for each technical finding.





## Attack Timeline

Timestamps UTC. Sources: [P] PCAP, [W] Wazuh, [H] host logs. The Caldera implant predates the entire captured window.

| <i>Time (UTC)</i>         | <i>Src</i> | <i>Event</i>                                                                      |
|---------------------------|------------|-----------------------------------------------------------------------------------|
| 9 May 07:48               | [W]        | First FTP connection from 172.16.50.10 (recon begins ~15h before exploit)         |
| 9 May 13:23 - 19:05       | [W]        | Continued slow-paced FTP recon (20-90 min cadence)                                |
| 9 May 20:08:30            | [P]        | PCAP starts: Caldera Sandcat already beaconing to 10.40.0.200:8888                |
| 9 May 20:12:36            | [P]        | FTP banner exposes vsFTPD 2.3.4; multi-protocol recon follows                     |
| 9 May 22:53:31            | [P]        | EXPLOIT: USER baduser:) sent (CVE-2011-2523 backdoor triggered)                   |
| 9 May 22:53:35            | [P]        | Root bind shell on TCP/6200 opened; attacker connects                             |
| 9 May 22:53:36 - 22:53:54 | [P]        | 8 root enum commands (id, whoami, uname, hostname, passwd, ls, ifconfig, netstat) |
| 9 May ~22:53:55           | [P]        | Bind shell closes (~20s); no persistence, no exfiltration                         |
| 10 May 01:39              | [P]        | End of PCAP capture                                                               |
| 11 May 13:17 - 13:28      | [W]        | Bulk ingestion of 397 events; 4 retrospective level-10 alerts                     |

## Indicators of Compromise

| Type            | Value                                           | Context                                                 |
|-----------------|-------------------------------------------------|---------------------------------------------------------|
| IPv4 (attacker) | 172.16.50.10                                    | vsftpd exploit, recon, SSH brute-force (I2-I4, I6, I7)  |
| IPv4 (target)   | 192.168.10.10                                   | Compromised internal NexaCorp server (Metasploitable 2) |
| IPv4 (C2)       | 10.40.0.200:8888                                | MITRE Caldera C2 endpoint, external, non-NexaCorp (I5)  |
| TCP port        | 6200                                            | Backdoor bind shell (vsftpd 2.3.4 CVE-2011-2523) (I4)   |
| Signature       | USER argument ending in the smiley sequence     | CVE-2011-2523 backdoor trigger (I3)                     |
| Signature       | 220 (vsFTPD 2.3.4) banner                       | Vulnerable service exposure (I1)                        |
| Signature       | POST /beacon + Go-http-client/1.1 UA            | Caldera Sandcat beacon (I5)                             |
| Host artifact   | /opt/caldera/sandcat (PID 4749, paw=mesdec)     | Caldera agent, root, quarantine + image (I5)            |
| Wazuh rule      | 5403 (first time user executed sudo), 2 firings | Post-exploit signal (I8)                                |

## Investigation Technical Summary

### I1. vsftpd 2.3.4 vulnerable service exposed

---

**Severity:****CRITICAL**

---

**Finding type:**Application-related vulnerability (vulnerable deployment)

---

**CVSS v3.1 base score:**10.0 (Critical) - AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

---

**CWE:**CWE-1395 (Dependency on Vulnerable Third-Party Component), chained with CVE-2011-2523

---

**MITRE ATT&CK:**T1190 (Exploit Public-Facing Application)

---

**Affected scope:**

- 192.168.10.10:21 (NexaCorp internal FTP server)
- 

**Description:**

The host exposes vsftpd 2.3.4 on TCP/21 : the build backdoored in July 2011 (CVE-2011-2523, CVSS 10.0). Any FTP client sending a USER command whose argument ends with the smiley byte sequence makes vsftpd fork a child that binds an unauthenticated root shell on TCP/6200. Its presence in 2026, fifteen years after disclosure, indicates serious gaps in asset inventory, patch management and vulnerability scanning.

**Recommendation:**

Decommission or upgrade vsftpd ( $\geq 3.0.x$ ), prefer SFTP/SCP; add the banner to the asset ban-list; schedule monthly vuln scans; deploy Suricata R2 as defence-in-depth.

## I2. Extended low-and-slow reconnaissance

---

**Severity:**

MEDIUM

---

**Finding type:**

Threat-actor behaviour (TTPs)

---

**CVSS v3.1 base score:**

5.3 (Medium) - AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

---

**CWE:**

N/A (TTP characterisation)

---

**MITRE ATT&CK:**

T1595.002, T1589, T1078.003

---

**Affected scope:**

- attacker 172.16.50.10
- 

**Description:**

The attacker probed the target for at least 15 hours before exploiting (earliest FTP CONNECT 07:48 UTC, exploit 22:53 UTC), at a deliberately slow 20-90 minute cadence to evade rate-based rules. Two patterns : anonymous content mapping, and username enumeration using the literal password 'wrongpassword' (the goal was timing-based account discovery, not credential guessing).

**Recommendation:**

Deploy a network IDS (Suricata R7, slow FTP enumeration); add SIEM correlation aggregating cross-protocol recon from one source over a 6-hour window; add source-IP reputation lookups at the firewall.

### 13. CVE-2011-2523 exploitation (USER smiley)

---

**Severity:**

**HIGH**

---

**Finding type:**

Successful exploitation event

---

**CVSS v3.1 base score:**

9.8 (Critical base, rated High at event level) - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

---

**CWE:**

CWE-78 (Improper Neutralization of Special Elements in an OS Command)

---

**MITRE ATT&CK:**

T1190, T1133 (External Remote Services)

---

**Affected scope:**

- event at 9 May 22:53:31 UTC
- 

**Description:**

At 22:53:31 the attacker sent a single FTP USER command ending in the smiley sequence, triggering the backdoor (I1). It is the only FTP attempt in the 5h30 capture that does not end with QUIT : the signature of successful activation. vsftpd does not log its own exploitation (the shell is forked before any session log entry), so detection must occur at the network layer or via host execve monitoring.

**Recommendation:**

Primary remediation is I1 (remove the service). As defence-in-depth, deploy Suricata R1 (near-zero FP, no legitimate client uses a smiley username).

**Evidence:**

```
tshark -r attack.pcap -Y 'ftp.request.command=="USER"' ... -> USER <...smiley> at 22:53:31
[FTP flow then terminates with no QUIT - signature of successful backdoor activation]
```

#### 14. Unauthenticated root bind shell on TCP/6200

---

**Severity:****CRITICAL**

---

**Finding type:**Active root-level compromise

---

**CVSS v3.1 base score:**10.0 (Critical) - AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

---

**CWE:**CWE-78 chained with CWE-269 (Improper Privilege Management)

---

**MITRE ATT&CK:**T1059.004, T1033, T1082, T1087.001, T1083, T1016, T1049

---

**Affected scope:**

- 192.168.10.10:6200, ~20-second session
- 

**Description:**

~4 seconds after the exploit, the attacker connected to the backdoor listener and obtained an interactive root shell for ~20 seconds, running 8 cleartext enumeration commands : id (uid=0 root), whoami, uname -a (Linux 2.6.24, Metasploitable 2), hostname, cat /etc/passwd, ls /home, ifconfig, netstat (22 listening services). Reconnaissance only : no destructive action, no downloads, no persistence in this stream.

**Recommendation:**

P0 take the host offline and image disk+memory before cleanup; deny TCP/6200; deploy Suricata R3; configure auditd execve to catch a shell forked by a non-shell parent.

**Evidence:**

```
Follow tcp stream 70 (172.16.50.10:41174 -> 192.168.10.10:6200):
id -> uid=0(root) gid=0(root) groups=0(root)
uname -a -> Linux metasploitable 2.6.24-16-server
```

## 15. Pre-existing MITRE Caldera Sandcat C2 implant

### Severity:

**CRITICAL**

### Finding type:

Pre-existing compromise (active C2 channel)

### CVSS v3.1 base score:

9.6 (Critical) - AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:L

### CWE:

CWE-506 (Embedded Malicious Code)

### MITRE ATT&CK:

T1071.001, T1029, T1102

### Affected scope:

- C2 endpoint 10.40.0.200:8888 (external, non-NexaCorp)

### Description:

The host runs a MITRE Caldera Sandcat agent at /opt/caldera/sandcat as root (PID 4749, parent PID 1). It is already beaconing at the first PCAP packet (20:08:30 UTC) to 10.40.0.200:8888 over HTTP every 37-53s (2,218 packets, 572 KB over the window). It predates the FTP exploit and is most likely a separate, earlier compromise. The C2 sends no instructions during the capture (standby/long-dwell access). The server fingerprint (Server: Python aiohttp) is a standard Caldera deployment ; agent paw=mesdec, group=lab-unknown.

### Recommendation:

P0 IMMEDIATE : quarantine, image memory+disk before cleanup; investigate /opt/caldera/sandcat and persistence (systemd, cron, rc.local); implement an egress allowlist (would have prevented the beacon); deploy Suricata R4/R5; audit other hosts for the same artifacts.

### Evidence:

```
Decoded beacon (Base64
JSON): paw=mesdec host=metasploitable username=root privilege=Elevated
server=http://10.40.0.200:8888 group=lab-unknown | C2 reply: sleep 37, instructions []
```

## 16. Multi-protocol service enumeration

---

**Severity:**

LOW

---

**Finding type:**

Reconnaissance activity

---

**CVSS v3.1 base score:**

3.7 (Low) - AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

---

**CWE:**

CWE-200 (Information Exposure)

---

**MITRE ATT&CK:**

T1046 (Network Service Discovery), T1592.002

---

**Affected scope:**

- 192.168.10.10 (HTTP/SSH/SMTP/Telnet/MySQL)
- 

**Description:**

Beyond the FTP recon (I2), the attacker banner-grabbed five additional services from curl/Wget user-agents (automated tooling, not a browser), and enumerated HTTP paths matching common content-discovery wordlists (/admin, /login, /phpmyadmin). SSH was OpenSSH 4.7p1 (2007), Telnet and externally-exposed MySQL were reachable.

**Recommendation:**

Disable unused services (Telnet, external MySQL, phpMyAdmin); suppress service banners where supported; deploy Suricata R6 (admin-path enumeration from CLI user-agents).



## 17. SSH brute-force attempts (Wazuh)

---

**Severity:**

MEDIUM

---

**Finding type:**

Authentication brute-force activity

---

**CVSS v3.1 base score:**

5.3 (Medium) - AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

---

**CWE:**

CWE-307 (Improper Restriction of Excessive Authentication Attempts)

---

**MITRE ATT&CK:**

T1110, T1110.001

---

**Affected scope:**

- 192.168.10.10 SSH/PAM (172.16.50.10)
- 

**Description:**

The Wazuh export shows SSH/PAM authentication activity from 172.16.50.10 not visible in the PCAP (only 2 SSH banner grabs were captured), partly outside the capture window : 16 failed PAM logins (rule 5503), 12 scan attempts (5706), and two level-10 bursts (rule 5551) which are among the only four high-severity alerts of the whole incident.

**Recommendation:**

Enforce key-only SSH (disable password auth) on any reachable endpoint; configure fail2ban; escalate rule 5551 to immediate notification.

## 18. Anomalous sudo activity (first-time-sudo)

---

**Severity:**

HIGH

---

**Finding type:**

Post-exploitation indicator

---

**CVSS v3.1 base score:**

N/A (behavioural SIEM indicator)

---

**CWE:**

CWE-269 (Improper Privilege Management)

---

**MITRE ATT&CK:**

T1548.003 (Sudo and Sudo Caching)

---

**Affected scope:**

- 192.168.10.10 (Wazuh rule 5403)
- 

**Description:**

Wazuh rule 5403 (first time a user account executes sudo) fired twice : a classic post-exploitation signal (an account that never used sudo suddenly does). Among 61 sudo-to-root and 17 sudo events, these two first-time events stand out and their timing relative to the FTP exploit must be confirmed by pulling the full\_log field.

**Recommendation:**

Pull full\_log for all sudo events; correlate timestamps with the exploitation; review accounts with newly-acquired sudo; configure auditd execve monitoring on critical hosts.

## 19. Insufficient SIEM detection coverage

---

**Severity:**

HIGH

---

**Finding type:**

Detection-coverage gap

---

**CVSS v3.1 base score:**

N/A (control-effectiveness finding)

---

**CWE:**

CWE-778 (Insufficient Logging), CWE-1120 (Excessive Code Complexity of alerts)

---

**MITRE ATT&CK:**

T1562 (Impair Defenses, by omission)

---

**Affected scope:**

- NexaCorp Wazuh SIEM
- 

**Description:**

Of 397 events ingested for the host, 88.4% were level-3 informational and only 4 (1.0%) reached level 10. The four high-severity alerts caught the brute-force fingerprint but surfaced neither the CVE-2011-2523 exploitation, the post-exploit root shell, nor the Caldera C2 channel. In a real SOC queue those four would have been dismissed as routine brute-force noise.

**Recommendation:**

Author correlation rules combining brute-force signals (11452, 5551, 5503) with first-time-sudo (5403) within a short window to elevate severity; deploy the seven Suricata rules delivered with this engagement.

## I10. Host audit log gap

---

**Severity:**

LOW

---

**Finding type:**

Evidence-coverage limitation

---

**CVSS v3.1 base score:**

N/A (logging gap)

---

**CWE:**

CWE-778 (Insufficient Logging)

---

**MITRE ATT&CK:**

N/A

---

**Affected scope:**

- 192.168.10.10 host logs
- 

**Description:**

The host audit logs do not cover the incident window : the earliest post-incident syslog entry is the next morning (syslogd restart, likely a VM reboot). The exploitation, the root shell and the implant activity left no host-log trace available in the evidence, forcing reliance on the PCAP and SIEM.

**Recommendation:**

Enable extended log retention ( $\geq 90$  days) and ship logs off-host in near-real-time to the central SIEM so the window is preserved next time.

## Risk Matrix

Each finding plotted by Impact against Likelihood. Upper-right is the most urgent.

| Impact / Likelihood | Very Low (1) | Low (2) | Medium (3) | High (4) | Very High (5) |
|---------------------|--------------|---------|------------|----------|---------------|
| Very High (5)       |              |         |            | I3, I5   | I1, I4        |
| High (4)            |              |         | I8         | I9       |               |
| Medium (3)          |              |         |            | I7       |               |
| Low (2)             |              | I10     | I6         | I2       |               |
| Very Low (1)        |              |         |            |          |               |

|          |      |        |     |
|----------|------|--------|-----|
| Critical | High | Medium | Low |
|----------|------|--------|-----|

I1 (vulnerable service), I4 (root shell) and I5 (active C2) are Critical ; I3, I8 and I9 are High ; I2 and I7 Medium ; I6 and I10 Low. I5 is the highest long-term concern (a standing external access channel).

## MITRE ATT&amp;CK Mapping

| <i>Finding</i> | <i>Tactic</i>                 | <i>Technique ID</i>                          | <i>Technique Name</i>                               |
|----------------|-------------------------------|----------------------------------------------|-----------------------------------------------------|
| I1/I3          | Initial Access                | <b>T1190, T1133</b>                          | Exploit Public-Facing App; External Remote Services |
| I2/I6          | Reconnaissance / Discovery    | <b>T1595.002, T1046, T1592.002</b>           | Active Scanning; Network Service Discovery          |
| I4             | Execution / Discovery         | <b>T1059.004, T1033, T1082, T1083, T1049</b> | Unix Shell; System/Account/Network Discovery        |
| I5             | Command and Control           | <b>T1071.001, T1102, T1029</b>               | Web Protocols; Web Service; Scheduled Transfer      |
| I7             | Credential Access             | <b>T1110.001</b>                             | Brute Force: Password Guessing                      |
| I8             | Privilege Escalation          | <b>T1548.003</b>                             | Sudo and Sudo Caching                               |
| I9             | Defense Evasion (by omission) | <b>T1562</b>                                 | Impair Defenses (detection gap)                     |

Framework : MITRE ATT&CK Enterprise v15.

## Detection Engineering (Phase 2)

Seven Suricata rules (SID 9000001-9000007) were authored against the captured PCAP, one per attack stage, and validated by offline replay (tcpreplay into a monitored interface; alerts inspected in fast.log/eve.json). Each rule fired correctly for its stage with no false positives across the 5,194-packet capture.

| <i>Rule (SID)</i> | <i>Detection</i>                     | <i>Buffer / logic</i>                                         | <i>Finding</i> |
|-------------------|--------------------------------------|---------------------------------------------------------------|----------------|
| R1 (9000001)      | vsftpd 2.3.4 USER smiley exploit     | TCP/21 payload, pcre on the USER smiley                       | I3             |
| R2 (9000002)      | vsftpd 2.3.4 vulnerable banner       | TCP/21 server greeting (220 vsFTPd 2.3.4)                     | I1             |
| R3 (9000003)      | Inbound TCP/6200 backdoor connection | SYN to port 6200, 1 alert/src/min                             | I4             |
| R4 (9000004)      | Caldera Sandcat beacon               | TCP content POST /beacon + Go-http-client/1.1 (port-agnostic) | I5             |
| R5 (9000005)      | Caldera C2 server response           | TCP content Server: Python aiohttp, throttled                 | I5             |
| R6 (9000006)      | HTTP admin-path enumeration          | GET /admin,/login,/phpmyadmin from curl/Wget, 3/300s          | I6             |
| R7 (9000007)      | Slow FTP USER enumeration            | 5+ USER from one src in 30 min (low-and-slow recon)           | I2             |

Tuning note : R4 was first written as alert http, but the HTTP parser only inspects port 80 by default while Caldera C2 runs on 8888 ; it was rewritten port-agnostic (alert tcp + content match) so the beacon is detected on any port. In the lab both endpoints are RFC1918, so the rules use any/any ; in production they must be scoped to the server IPs and use flow:established. The full rule text and false-positive analysis are in the detection/ folder.

## Remediation

### *P0 - immediate*

- Quarantine the host; acquire memory and disk images before any cleanup (I4, I5).
- Investigate /opt/caldera/sandcat (PID 4749) and enumerate persistence; implement an egress allowlist (I5).
- Decommission or upgrade vsftpd 2.3.4; deny inbound TCP/6200 (I1, I4).

### *Short to medium term*

- Deploy the seven Suricata rules on the segment ingress/egress; deploy a network IDS where none exists (I2, I9).
- Author Wazuh correlation rules elevating brute-force + first-time-sudo; escalate rule 5551 to immediate notification (I7, I8, I9).
- Disable unused services and suppress banners (I6); enforce key-only SSH (I7).
- Enable >= 90-day log retention with near-real-time off-host shipping to the SIEM (I10).
- Audit configuration management to determine how a 2011-vintage package reached production (I1).



## Tools and Standards

### A. Tools used during the engagement

| <i>Category</i>          | <i>Tool</i>                | <i>Purpose</i>                                                   |
|--------------------------|----------------------------|------------------------------------------------------------------|
| Network capture analysis | Wireshark / tshark         | PCAP triage, TCP stream follow, exploit-signature identification |
| SIEM                     | Wazuh 4.x                  | Event correlation, severity distribution, IOC consolidation      |
| Detection engineering    | Suricata 6.0.4 + tcpreplay | Author and validate the seven IDS rules by offline replay        |
| Decoding                 | base64 / CyberChef         | Decode the Caldera beacon JSON payloads                          |
| Documentation            | VS Code, Markdown          | Note-taking and report drafting                                  |

**B. Standards and frameworks followed**

| <i><b>Standard / Framework</b></i> | <i><b>Version</b></i> | <i><b>Application</b></i>                                    |
|------------------------------------|-----------------------|--------------------------------------------------------------|
| NIST SP 800-61r2                   | 2012                  | Incident handling methodology                                |
| NIST SP 800-86                     | 2006                  | Forensic technique integration                               |
| SANS PICERL                        | -                     | Incident response phases                                     |
| MITRE ATT&CK Enterprise            | v15                   | Technique mapping                                            |
| CVSS                               | v3.1                  | Severity scoring                                             |
| CWE                                | v4.16                 | Root-cause classification (CWE-1395, 78, 269, 506, 307, 778) |
| Suricata rule syntax               | -                     | Detection rule authoring (SID 9000001-9000007)               |

## Glossary and Acronyms

| <i><b>Acronym</b></i> | <i><b>Full Name</b></i>                              | <i><b>Description</b></i>                                               |
|-----------------------|------------------------------------------------------|-------------------------------------------------------------------------|
| vsftpd                | Very Secure FTP Daemon                               | The FTP server; version 2.3.4 carries the CVE-2011-2523 backdoor        |
| CVE-2011-2523         | vsftpd 2.3.4 backdoor                                | USER ending in a smiley opens an unauthenticated root shell on TCP/6200 |
| Bind shell            | Bind shell                                           | A shell bound to a listening port the attacker connects to              |
| C2                    | Command and Control                                  | Channel through which an attacker controls a compromised host           |
| Caldera / Sandcat     | MITRE Caldera / Sandcat agent                        | Open-source post-exploitation framework and its implant                 |
| IDS / NIDS            | (Network) Intrusion Detection System                 | Detects malicious traffic (here Suricata)                               |
| SIEM                  | Security Information and Event Management            | Log aggregation and alerting (here Wazuh)                               |
| PCAP                  | Packet Capture                                       | Captured network traffic                                                |
| IOC                   | Indicator of Compromise                              | Artifact pointing to malicious activity                                 |
| MITRE ATT&CK          | Adversarial Tactics, Techniques and Common Knowledge | Threat behaviour framework                                              |
| CVSS                  | Common Vulnerability Scoring System                  | Standard severity score for vulnerabilities                             |
| CWE                   | Common Weakness Enumeration                          | Classification of software weaknesses                                   |

## BeCode Corp.

*DFIR / SOC Training*

**Reference: BCC-2026 | INC-2026-001**

Classification: Internal - Not for distribution

Analyst

**Johan-Emmanuel Hatchi, SOC Analyst L1**

*BeCode Cybersecurity Bootcamp - Promotion 2025-2026*

[linkedin.com/in/johan-emmanuel-hatchi](https://linkedin.com/in/johan-emmanuel-hatchi)

[github.com/Jhatchi](https://github.com/Jhatchi)